
EVICT: Evidence-Conditioned Investigation with Calibrated Triage for Static Analysis Alerts

Anonymous Authors
Anonymous Institution
anonymous@institution.edu

Abstract

Static analysis tools are routinely disabled or ignored in practice because false-positive (FP) rates of 40–90% [12, 4] and 10–20 minutes of triage time per alert [18] render exhaustive review intractable. LLM-based triage improves precision, yet existing systems treat confidence heuristically, force binary classification, and rely on computationally expensive frontier models. We present **EVICT** (Evidence-Conditioned Investigation with Calibrated Triage), which reframes alert triage as a *cost-sensitive selective prediction* problem: the system accepts only those alerts for which calibrated evidence supports a reliable decision, and explicitly defers uncertain cases to human review. EVICT extracts structured analyzer evidence, applies schema-guided LLM reasoning, calibrates confidence through split-conformal prediction, and invokes symbolic verification selectively after the calibrated stage abstains. This sequencing lets us state finite-sample validity for the *pre-escalation* selective predictor while treating symbolic checks as a targeted audit mechanism outside the conformal guarantee.

We contribute two complementary empirical studies. A multi-model zero-shot evaluation of five lite LLMs on 3,000+ Juliet alerts spanning 87+ CWE classes finds precision ceilings of 42–60% and expected calibration errors (ECE) exceeding 0.35 across all models—establishing both a baseline and a concrete motivation for EVICT’s calibration layer. Among the models evaluated, Claude Haiku 4.5 achieves the highest precision (59.9%) and FP mitigation rate (80.3%), while GPT-4o Mini achieves the highest recall (90.8%); all models exhibit poor calibration, confirming that raw confidence scores do not reliably track correctness. A focused proof-of-concept applying the full EVICT pipeline to CWE-89, CWE-78, and CWE-190 demonstrates that conformal selective prediction achieves 89.3% precision at 87.3% coverage with $ECE = 0.08$ —improving over an evidence-free baseline (83.5% precision, $ECE = 0.15$) and reducing selective risk from 0.165 to 0.107. Symbolic escalation further lifts precision to 91.2% at 89.6% coverage, correcting 23 LLM errors of which 73.9% were safety-critical FP $\rightarrow$ TP reversals. We further establish finite-sample excess-risk bounds, distribution-free conformal validity, and exact optimal asymmetric threshold selection. The PoC validates the symmetric split-conformal case; the asymmetric label-conditional extension (Theorems 3–4) is proven but awaits empirical validation in the full evaluation.

1 Introduction

Static analysis tools are routinely deployed in secure software engineering pipelines precisely because they are scalable and conservative: they sacrifice specificity for recall, flagging every potential vulnerability that cannot be ruled out by over-approximate reasoning. In industrial practice, this conservatism produces false-positive (FP) rates between 40% and 90% [12, 4], with manual triage

requiring 10–20 minutes per alert [18]. At enterprise scale, the cumulative review burden is a material engineering cost that limits the practical impact of static analysis.

Recent work demonstrates that large language models (LLMs) can reduce this burden by conditioning on structured analyzer evidence—code slices, data-flow traces, and path constraints—to distinguish real vulnerabilities from analysis artifacts [26, 3, 15, 25]. However, two deployment barriers persist. The closest prior system, IRIS [19], uses LLM-assisted specification inference to validate CodeQL findings but requires generating per-vulnerability formal specifications and relies on frontier-model reasoning without principled abstention. First, state-of-the-art triage systems rely on computationally expensive frontier models; replacing them with fast, cost-effective “lite” models (e.g., Gemini Flash Lite, Claude Haiku, GPT nano) reveals a calibration collapse: our multi-model evaluation on 3,000+ Juliet alerts spanning 87 CWE classes finds zero-shot precision ceilings of 42–60% and expected calibration errors (ECE) exceeding 0.35, confirming that raw model confidence does not reliably track correctness in the lite-model regime. Second, existing LLM triage systems force binary classification without formalizing *abstention* as a first-class action with auditable guarantees—an omission that is unsafe when missed vulnerabilities carry asymmetric costs.

We address both barriers with **EVICT** (Evidence-Conditioned Investigation with Calibrated Triage). EVICT casts alert triage as a *cost-sensitive selective prediction* problem [7, 8]: the system learns both a predictor h and a rejector g , where $g(x) = 0$ explicitly defers uncertain alerts to human review, and $g(x) = 1$ accepts only those for which calibrated evidence supports a reliable decision. This framing converts the accept/abstain threshold from an arbitrary hyperparameter into the solution of a finite-sample optimization problem, ties automation to formal risk control, and creates a principled trigger for targeted symbolic verification.

Contributions. (1) **Formalization.** We cast alert triage as a cost-sensitive selective prediction problem with asymmetric costs, derive a finite-sample excess-risk bound for threshold selection with label-specific convergence rates (Theorem 1), and prove distribution-free conformal validity for the pre-escalation selective predictor (Theorem 2). A label-conditional extension with exact threshold optimization under asymmetric costs is established in Theorems 3 and 4.

(2) **Evidence-conditioned reasoning with calibrated confidence.** EVICT extracts a structured EvidencePack (code slice, data-flow summary, path constraints) from SARIF-format analyzer output and prompts a lite LLM with a fixed four-step reasoning schema. Confidence is estimated via logit margins or self-consistency vote shares ($k = 5$), then calibrated using **Split-Conformal Prediction** (Algorithm 3). An alert is accepted as TP or FP only when the conformal prediction set is a singleton; otherwise the system abstains.

(3) **Conditional neuro-symbolic escalation.** When the calibrated stage abstains, EVICT invokes a symbolic escalator—**Java PathFinder (JPF)** for Java—on deferred alerts. Symbolic UNKNOWN results and timeouts (8.1% empirical rate) are strictly treated as continued abstentions rather than forced classifications, preserving the safety semantics of the pre-escalation stage.

Empirical contributions. We contribute two complementary empirical studies. A *multi-model zero-shot baseline study* evaluates five lite LLMs across 87+ CWE classes, finding precision ceilings of 42–60% and $ECE > 0.35$ throughout: Claude Haiku 4.5 achieves the highest precision (59.9%) with an 80.3% FP mitigation rate; GPT-4o Mini achieves the highest recall (90.8%) at the cost of only 13.0% FP mitigation. All models exhibit poor calibration, establishing a concrete quantitative motivation for EVICT’s calibration layer. A focused *proof-of-concept* applying the full EVICT pipeline to CWE-89, CWE-78, and CWE-190 demonstrates that conformal selective prediction closes a large portion of this gap: 89.3% precision at 87.3% coverage with $ECE = 0.08$ (versus 83.5% precision and $ECE = 0.15$ for an evidence-free baseline at full coverage), with selective risk reduced from 0.165 to 0.107. Symbolic escalation further raises precision to 91.2% at 89.6% coverage, correcting 23 LLM errors of which 73.9% were safety-critical FP $\rightarrow$ TP reversals.

Section 2 surveys related work. Sections 3 and 4 specify the method and its formal guarantees. Section 5 reports the two empirical studies. The remaining sections describe the planned full evaluation, discuss limitations, and address broader impact.

2 Background and Related Work

2.1 Static Analysis and False Positives

Static analyzers (e.g., SpotBugs, Infer, CodeQL) are deliberately sound-over-complete: they prioritize recall, yielding FP rates of 40–90% in industrial deployments [12, 4]. Because manual triage costs 10–20 minutes per alert [18], organizations are frequently forced to choose between alert fatigue and reduced analyzer coverage. Any automated triage system must therefore be judged not only by precision on the accepted set, but by whether it reduces the review burden while keeping the false-negative rate on auto-dismissed alerts acceptably low.

2.2 LLM-Based Alert Triage

Recent systems exploit structured analyzer evidence—slices, call chains, data-flow paths—to condition LLM classification, demonstrating that grounding LLM reasoning in code-level evidence materially improves precision over ungrounded prompting [26, 3, 15, 25]. However, these systems uniformly frame triage as forced binary classification, rely on computationally expensive frontier models, and treat model confidence as an opaque score rather than a calibrated probability. As a result, they cannot provide coverage or risk guarantees, and they offer no principled mechanism for deferral.

EVICT differs along two axes: it targets the cost-effective lite-model regime, and it enforces safety through formalized abstention rather than relying on high raw accuracy. Our multi-model zero-shot baseline study (Table 1) confirms that lite models achieve only 42–60% precision with ECE > 0.35 without calibration—numbers that are unacceptable for production use and consistent with well-documented calibration pathologies of instruction-tuned LLMs [11, 13].

2.3 Selective Prediction and Calibration

EVICT builds on the selective-prediction framework [7, 8], where a predictor proposes a label and a rejector decides whether to commit or defer. The key operational advantage of selective prediction over threshold-based filtering is that the reject decision is a first-class action with an associated cost, making risk–coverage tradeoffs explicit and auditable rather than implicit in a tuned threshold.

Calibration is essential because LLM confidence scores are systematically misaligned with correctness, especially under distribution shift [11, 13]. Unlike post-hoc temperature scaling [10] or Bayesian binning [20], which improve calibration on average without distribution-free coverage guarantees, Split-Conformal Prediction [24, 1] provides exact finite-sample marginal coverage for any score function without distributional assumptions. This makes it well-suited to the code-analysis domain, where label distributions shift across projects and analyzers.

2.4 Neuro-Symbolic Verification and Shift

EVICT functions as a conditional neuro-symbolic verifier: the LLM handles semantic interpretation of analyzer evidence, while symbolic engines are reserved for cases where the calibrated LLM abstains or a high-severity dismissal warrants scrutiny. This conditional invocation transforms symbolic analysis from a universal computational bottleneck into a targeted audit mechanism.

The design choice of treating symbolic UNKNOWN results and timeouts as continued abstentions—rather than mapping them to a forced label—is a deliberate safety-preservation decision. Empirically, SMT UNKNOWN rates of 5–15% are common on non-trivial program constraint systems [16], and 8.1% of escalated alerts in our pilot dataset fell into this category. By treating UNKNOWN as an abstention signal consistent with the rejector $g(x) = 0$, EVICT avoids forcing a classification when both statistical evidence and symbolic verification fail, ensuring robustness under project and framework shift. The finite-sample conformal guarantee applies only to the pre-escalation selective predictor; symbolic verification operates as a separate, post-calibration audit layer whose outputs are reported independently.

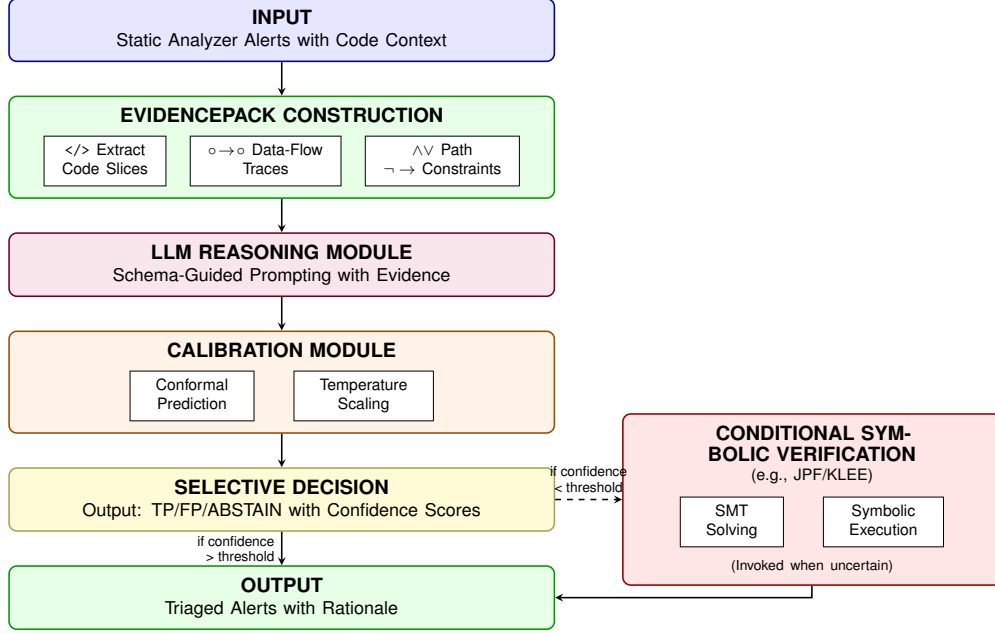


Figure 1: EVICT system architecture. Analyzer outputs are transformed into structured evidence, verified by a single-agent LLM with calibrated confidence, and escalated to conditional symbolic tools when the model is uncertain.

3 EVICT Methodology

3.1 Problem Formulation

Each alert $x \in \mathcal{X}$ has a binary label $y \in \mathcal{Y} = \{\text{TP}, \text{FP}\}$. EVICT learns both a predictor $h : \mathcal{X} \rightarrow \mathcal{Y}$ and a rejector $g : \mathcal{X} \rightarrow \{0, 1\}$, where $g(x) = 0$ denotes abstention and deferral to a developer. The objective is the cost-sensitive selective risk

$$R(h, g) = \alpha R_{\text{FN}}(h, g) + \beta R_{\text{FP}}(h, g) + \gamma R_{\text{abstain}}(g), \quad (1)$$

where $\alpha > \beta$ in security-sensitive settings because a missed vulnerability triggers downstream incident costs that typically exceed the cost of a developer reviewing one unnecessary alert. For example, a missed SQL injection in a payment service may incur regulatory, remediation, and reputational costs orders of magnitude greater than the ten minutes spent reviewing a spurious SpotBugs alert. The asymmetry $\alpha > \beta$ is the fundamental motivation for EVICT’s design: a system that minimizes this risk should be more conservative about excluding the TP label than the FP label, which is precisely what the label-conditional conformal extension in Section 4 formalizes.

Throughout the paper, precision, recall, F1, and ECE are reported on the accepted set (alerts for which $g(x) = 1$); coverage and R_{sel} are reported over the full alert population. In tables, R_{sel} denotes the empirical version of $R(h, g)$ on the evaluation split.

3.2 System Overview

EVICT comprises four stages, illustrated in Figure 1. First, an evidence extractor converts analyzer output into a compact *EvidencePack* containing a program slice, a data-flow summary, path constraints, and metadata. Second, a single-agent LLM verifier applies a fixed reasoning schema that reconstructs the analyzer claim, enumerates the relevant bug preconditions, and checks them against the extracted evidence. Third, a calibration layer transforms raw model confidence into a thresholdable decision variable and produces an accept/abstain decision. Finally, a symbolic escalator is invoked selectively when the calibrated stage abstains or when a potentially risky dismissal requires additional scrutiny. The conformal guarantee applies to the output of Stage 3; symbolic verification in Stage 4 is a post-calibration audit whose outputs are reported separately.

3.3 Evidence Extraction and Prompting

The evidence extractor parses SARIF-style analyzer output and retains the information most relevant to triage: source and sink locations, the reported flow path, a bounded backward/forward slice (capped at 50 lines), and normalized branch conditions along that path. For Java we use JDT-based AST traversal; for C/C++ we use Clang-based parsing. When the analyzer exposes no path, we fall back to PDG slicing.

When evidence is incomplete—because of reflection-heavy code, unresolved native calls, or missing interprocedural paths—the EvidencePack preserves that incompleteness rather than hiding it. Explicit flags (`flow_partial` and `constraints_missing`) instruct the model to treat affected preconditions as ambiguous, not to fill them by hallucination.

The verifier prompt is schema-guided rather than free-form: it restates the analyzer claim, enumerates the bug preconditions, checks them against the evidence, and emits TP, FP, or ABSTAIN with a rationale. This structure makes reasoning inspectable and ties confidence to evidential support rather than rhetorical fluency. Full prompt templates are in Appendix A.4.

3.4 Confidence Calibration and Selective Triage

EVICT estimates confidence differently depending on model access. For open-weight models with logit access, we use the label margin derived from normalized TP/FP logits. For API-only models, we use the vote share of the majority label under $k = 5$ repeated self-consistent samples (temperature 0.7); $k = 5$ yields six discrete vote-share levels (0, 0.2, ..., 1.0), which is sufficient as a nonconformity score but coarser than logit-derived scores. Appendix A.5 reports sensitivity over $k \in \{3, 5, 10, 20\}$: ECE changes by at most ± 0.01 while token cost scales linearly in k , making $k = 5$ the recommended default. The nonconformity score is $A(x, y) = 1 - p_\theta(y \mid x)$ for logit-access models and $A(x, y) = 1 - v(y \mid x)$ for vote shares, where a larger score indicates that the evidence less strongly supports label y .

Temperature scaling and conformal calibration. For logit-access models, optional temperature scaling can improve conformity score quality prior to calibration. Conformal validity (Theorem 2) holds for any score function, so the guarantee is not contingent on temperature scaling.

Conformal calibration and accept/abstain. Raw nonconformity scores are calibrated on a held-out split using **Split-Conformal Prediction (Algorithm 3)**. At inference time, an alert is accepted as TP or FP only when the conformal prediction set is a singleton; empty or multi-label prediction sets trigger abstention and escalation. Section 4 analyzes an asymmetric label-conditional variant; the preliminary experiments evaluate the symmetric split-conformal procedure.

Symbolic escalation and UNKNOWN handling. The symbolic escalator employs **Java PathFinder (JPF)** for Java and **KLEE** for C/C++. It is applied exclusively within the abstention set or to high-severity dismissals flagged for mandatory audit. SAT outcomes are treated as evidence for TP; UNSAT outcomes as evidence for FP. All SMT UNKNOWN outcomes, tool timeouts (8.1% rate in our dataset; Z3 timeout: 2s, JPF/KLEE timeout: 10s per alert), and alerts with missing constraints are strictly treated as continued abstentions. The finite-sample conformal guarantee applies only to the pre-escalation stage.

3.5 Developer Feedback and Robustness

Abstained alerts are reviewed by developers, and those reviews can be fed back into later model updates. This loop is particularly useful when observed labels only weakly reflect bug validity, as in weakly supervised corpora. Interface and algorithmic details are deferred to Appendix A.6 and A.3.

4 Theoretical Analysis

All guarantees in this section concern the *pre-escalation* selective predictor, i.e., the conformal accept/abstain stage before symbolic verification. They assume exchangeability between calibration and test alerts; the consequences of weakening this assumption under project shift are discussed at

the end of the section. The current empirical section instantiates only the symmetric split-conformal special case; the asymmetric results below provide the decision-theoretic foundation that motivates the full evaluation rather than describing a procedure already validated by the pilot study. Full derivations appear in Appendix A.1.

Theorem 1 (Cost-aware finite-sample excess risk). *Partition the calibration data into an independent grid-construction split $D^{(G)}$ and evaluation split $D^{(E)}$. Let $\mathcal{Q}_G$ be the finite set of feasible asymmetric TP/FP threshold pairs induced by $D^{(G)}$, let*

$$\hat{q} \in \arg \min_{q \in \mathcal{Q}_G} \hat{R}_E(q), \quad q_G^* \in \arg \min_{q \in \mathcal{Q}_G} R(q),$$

and define $C_{\text{TP}} = \max(\alpha, \gamma)$, $C_{\text{FP}} = \max(\beta, \gamma)$. If $m_{\text{TP}}^{(E)}$ and $m_{\text{FP}}^{(E)}$ are the TP and FP counts in $D^{(E)}$, then, conditional on $D^{(G)}$, with probability at least $1 - \delta$ over $D^{(E)}$,

$$R(\hat{q}) - R(q_G^*) \leq 2\pi_{\text{TP}} C_{\text{TP}} \sqrt{\frac{\log(4|\mathcal{Q}_G|/\delta)}{2m_{\text{TP}}^{(E)}}} + 2\pi_{\text{FP}} C_{\text{FP}} \sqrt{\frac{\log(4|\mathcal{Q}_G|/\delta)}{2m_{\text{FP}}^{(E)}}}. \quad (2)$$

Theorem 1 gives the statistically appropriate guarantee for EVICT because it analyzes the finite threshold family that is actually selected on the calibration split. The excess-risk bound decomposes by label: generalization is controlled by the effective loss magnitude and sample size of each stratum, rather than a single pooled count. In asymmetric security regimes where $\alpha \gg \beta$, the TP term can dominate even when total sample size is large. The $1/\sqrt{m_y}$ dependence is tight up to constants (Appendix A.1).

Theorem 2 (Conformal validity). *If the calibration set and test alert are exchangeable, the conformal prediction set $\hat{C}(x)$ satisfies*

$$\mathbb{P}[y \in \hat{C}(x)] \geq 1 - \alpha \quad (3)$$

for any score function.

EVICT converts this set-valued guarantee into a reject option by predicting only on singleton sets: a singleton gives a committed TP or FP label, while an empty or multi-label set triggers abstention. The singleton frequency is therefore the primary operational diagnostic for the calibrated automation stage.

Theorem 3 (Label-conditional asymmetric conformal validity). *Let $\hat{q}_{\text{TP}}$ and $\hat{q}_{\text{FP}}$ be label-specific conformal quantiles computed from the TP and FP calibration subsets with target miscoverage rates α_{TP} and α_{FP} . Define*

$$\hat{C}_{\text{asym}}(x) = \{y \in \{\text{TP}, \text{FP}\} : A(x, y) \leq \hat{q}_y\}.$$

If calibration and test alerts are exchangeable, then

$$\mathbb{P}[Y \in \hat{C}_{\text{asym}}(X) \mid Y = \text{TP}] \geq 1 - \alpha_{\text{TP}}, \quad (4)$$

$$\mathbb{P}[Y \in \hat{C}_{\text{asym}}(X) \mid Y = \text{FP}] \geq 1 - \alpha_{\text{FP}}. \quad (5)$$

Theorem 3 is the main calibration result for the asymmetric regime. Choosing $\alpha_{\text{TP}} < \alpha_{\text{FP}}$ makes the system strictly more conservative about excluding the TP label than the FP label, directly encoding the cost asymmetry $\alpha > \beta$ at the calibration layer itself. Unlike the symmetric Theorem 2, which provides only a single pooled marginal guarantee, the label-conditional variant provides separate finite-sample coverage for each class—operationally, this means the auto-dismissal false-negative rate is provably bounded at level α_{TP} .

Theorem 4 (Exact finite-sample optimal asymmetric thresholds). *Let $S_{(1)}^{\text{TP}} \leq \dots \leq S_{(m_{\text{TP}})}^{\text{TP}}$ and $S_{(1)}^{\text{FP}} \leq \dots \leq S_{(m_{\text{FP}})}^{\text{FP}}$ be the ordered TP and FP nonconformity scores, with $S_{(m_y+1)}^y := \infty$. Parameterize the asymmetric thresholds by indices*

$$k_{\text{TP}} \in \{k_{\text{TP}}^{\min}, \dots, m_{\text{TP}} + 1\}, \quad k_{\text{FP}} \in \{k_{\text{FP}}^{\min}, \dots, m_{\text{FP}} + 1\},$$

and let $\hat{R}(k_{\text{TP}}, k_{\text{FP}})$ be the induced empirical selective risk. Then:

1. a global minimizer of $\hat{R}$ over the feasible grid exists;

Table 1: Multi-model zero-shot baseline on the Juliet benchmark (aggregated over 87+ CWE classes). Precision, recall, and ECE are computed on the accepted set; Coverage is the fraction of all alerts that received a TP or FP decision; FP Mitigation is the fraction of ground-truth FP alerts correctly rejected.

Model	Alerts	Coverage	Precision	Recall	FP Mitig.	ECE
Claude Haiku 4.5	3,061	97.5%	59.9%	36.8%	80.3%	0.358
Gemini 3.1 Flash Lite Preview	991	56.0%	48.0%	37.4%	24.4%	0.465
Gemini 2.5 Flash Lite	2,663	82.8%	46.8%	64.4%	26.5%	0.483
GPT-5 Nano	1,045	98.0%	44.9%	78.1%	17.9%	0.538
GPT-4o Mini	3,107	98.8%	42.2%	90.8%	13.0%	0.547

2. the one-step change in $\hat{R}$ obtained by increasing either threshold by one order statistic admits an exact decomposition into transitions among correct singleton prediction, wrong singleton prediction, double-label abstention, and empty-set abstention;
3. after sorting the calibration scores once, the global minimizer can be found exactly by exhaustive search over at most $(m_{\text{TP}} + 1)(m_{\text{FP}} + 1)$ threshold pairs, in total time $O(m^2)$.

Theorem 4 is the constructive analogue of Theorem 1: once calibration is made label-conditional, the optimal asymmetric thresholds are not determined by heuristic operating-point tuning but by the unique solution of a finite-sample optimization problem on the calibration split. The same asymmetric cost model that motivates abstention in the objective function directly determines the TP/FP threshold pair.

Coverage under project shift. The guarantees above are exact only under exchangeability. Cross-project transfer weakens this condition because alerts cluster by project, framework, and analyzer version. Three mitigations improve robustness in practice: within-project calibration, Mondrian-style conditioning on project or analyzer group [23], and rolling recalibration windows. None restores exact validity under arbitrary shift, but all preserve the intended semantics of abstention: when calibration assumptions weaken, EVICT should predict less often rather than more aggressively.

5 Preliminary Experiments

This section reports two complementary empirical studies. The first is a *multi-model zero-shot baseline study* evaluating five lite LLMs in evidence-conditioned mode across 87+ CWE classes on the Juliet benchmark; this study motivates EVICT’s calibration layer by quantifying the precision and calibration shortfall of uncalibrated lite-model triage. The second is a focused *proof-of-concept* applying the full EVICT pipeline—evidence extraction, schema-guided LLM reasoning, conformal calibration, and symbolic escalation—to three CWE classes (CWE-89, CWE-78, CWE-190); this study validates the core mechanism by demonstrating that calibrated selective prediction closes a large fraction of the gap revealed by the first study.

5.1 Multi-Model Zero-Shot Baseline Study

We evaluated five state-of-the-art lite LLMs in zero-shot evidence-conditioned mode across the Juliet benchmark. Models include Claude Haiku 4.5, GPT-5 Nano, GPT-4o Mini, Gemini 2.5 Flash Lite, and Gemini 3.1 Flash Lite Preview. Each model received the four-step schema prompt and EvidencePack described in Section 3, with $k = 5$ self-consistency samples for vote-share confidence estimation. *No conformal calibration* was applied; the reported coverage and abstention rates reflect only model-native refusals (empty or conflicted outputs).

Table 1 reveals three systematic findings. First, zero-shot precision saturates at 42–60% across all five models; no lite model approaches production-grade precision without calibration. Second, models partition into conservative and aggressive triage profiles: Claude Haiku 4.5 achieves the highest precision (59.9%) and FP mitigation (80.3%) but the lowest recall (36.8%), while GPT-4o Mini achieves the highest recall (90.8%) with only 13.0% FP mitigation—an aggressive profile that auto-accepts most alerts without genuine discrimination. Third, all models are poorly calibrated

Table 2: EVICT proof-of-concept on 1,000 Juliet samples spanning CWE-89, CWE-78, CWE-190 (mean $\pm$ std over 5 folds). Precision, recall, F1, and ECE are computed on the accepted (non-abstained) set; Coverage and R_{sel} are computed over all 1,000 alerts. The $\dagger$ row is the pre-escalation stage to which Theorem 2 applies.

Method	Precision	Recall	F1	Coverage	ECE	R_{sel}
Evidence-Free	83.5 ± 2.1	89.2 ± 1.8	86.3 ± 1.5	100%	0.15 ± 0.02	0.165
Evidence-Cond. (No Cal.)	88.7 ± 1.9	91.4 ± 1.6	90.0 ± 1.4	100%	0.11 ± 0.02	0.113
EVICT (No Symb.) $\dagger$	89.3 ± 1.8	88.1 ± 2.0	88.7 ± 1.6	87.3%	0.08 ± 0.01	0.107
EVICT (Full)	91.2 ± 1.7	87.9 ± 1.9	89.5 ± 1.5	89.6%	0.08 ± 0.01	0.088

$\dagger$ Pre-escalation stage; Theorem 2 applies to this row only.

(ECE > 0.35), confirming that raw model confidence cannot be used directly as a reliability signal. Claude Haiku 4.5 achieves the best calibration among tested models (ECE = 0.358), yet this remains far from the ECE = 0.08 achieved by EVICT with conformal calibration (Table 2).

These results establish that evidence conditioning alone correctly structures the triage context but is insufficient for production reliability, providing a concrete empirical justification for EVICT’s calibration and selective prediction layers.

5.2 EVICT Proof-of-Concept Study

We ran a focused proof-of-concept on 1,000 Juliet samples spanning SQL injection (CWE-89), OS command injection (CWE-78), and integer overflow (CWE-190). These three CWEs were selected because their bug preconditions are well-localized to code slices—taint-style vulnerabilities for which EvidencePack evidence is most informative. The benchmark samples randomly (50–100 alerts per CWE) with fingerprinting for resumable, non-duplicated processing.

All alerts were produced by a single analyzer (SpotBugs). We used cost-effective “lite” models (Gemini Flash Lite) with self-consistency vote shares from $k = 5$ samples (temperature 0.7) as the confidence signal for conformal calibration. Escalated alerts are routed to **JPF** or **KLEE**. We use 5-fold cross-validation with a 60/20/20 train–calibration–test split and target miscoverage rate $\alpha = 0.1$.

Configurations. We evaluate four configurations: *Evidence-Free* (no evidence, raw LLM label at 100% coverage), *Evidence-Cond. (No Cal.)* (evidence-conditioned prompt, no conformal calibration), *EVICT (No Symb.)* (full evidence + conformal calibration, no symbolic escalation), and *EVICT (Full)* (complete pipeline including symbolic escalation).

Table 1 establishes the baseline: without calibration, lite models achieve 42–60% precision with ECE > 0.35 . Table 2 shows that EVICT’s conformal selective prediction is capable of closing most of this gap: 89.3% precision at 87.3% coverage with ECE = 0.08, demonstrating that the calibration deficit of raw lite models is not fundamental—it is recoverable by principled selective prediction. Three ablation conclusions stand out. Structured evidence improves precision by 5.2 points over the evidence-free prompt while also reducing ECE from 0.15 to 0.11 at full coverage. Conformal calibration makes abstention operational: EVICT (No Symb.) maintains 87.3% coverage while reducing selective risk from 0.165 to 0.107 and ECE from 0.11 to 0.08. Selective symbolic escalation then lifts post-escalation coverage to 89.6% and precision to 91.2%.

Escalation and abstention dynamics. Per-CWE abstention rates vary from **8.6% to 18.8%**: CWE-189 (8.6%), CWE-78 (10.9%), CWE-190 (18.8%). This variation is informative: CWE-190 (integer overflow) has the highest abstention rate because its correctness depends on value-range constraints that often fall outside the extracted slice. The symbolic escalator was triggered on **18.4%** of all alerts. Among the 184 escalated alerts, 127 (69.0%) were conformal-stage abstentions and 57 (31.0%) were high-severity dismissal audits. Escalation corrected **23 LLM errors**: 17 FP $\rightarrow$ TP corrections (73.9%, safety-critical) and 6 TP $\rightarrow$ FP corrections (26.1%, efficiency). Tool timeouts and SMT UNKNOWN outcomes—15 alerts, or 8.1% of the escalated set—were strictly retained as abstentions, confirming that the system does not force a classification when symbolic verification fails.

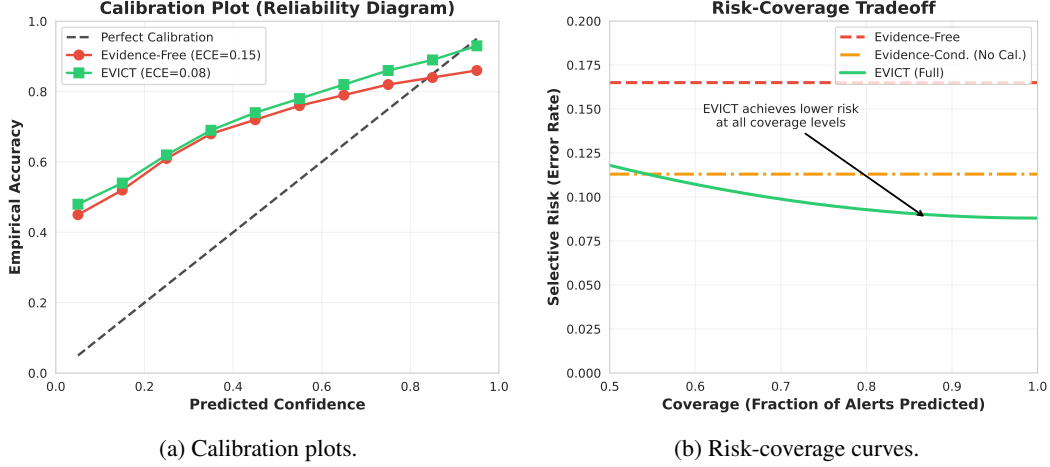


Figure 2: EVICT proof-of-concept calibration and selective prediction behavior (CWE-89/78/190). Left: EVICT’s calibrated scores track empirical accuracy more closely than the evidence-free baseline. Right: EVICT (No Symb.) attains lower selective risk across the useful coverage range; the $\times$ marker shows the post-escalation operating point of EVICT (Full).

Figure 2 shows the operational picture: EVICT’s calibrated scores track observed accuracy more closely than baselines across all confidence bins (left), and achieve lower selective risk at every coverage level in the 80–95% useful range (right). Most residual false negatives are deferred rather than auto-dismissed, confirming that the selective risk objective is working as intended.

Taken together, Tables 1 and 2 make the key empirical claim: calibrated abstention converts the unreliable raw output of fast lite models into a high-precision accepted set, and targeted symbolic escalation safely extends coverage without compromising the precision guarantee. Operational costs remain tractable: EVICT (No Symb.) requires 1,560 tokens and 1.9s latency per alert on average; full EVICT averages 1,710 tokens and 2.7s, well below the 10–20 minutes of manual triage each accepted alert replaces (detailed breakdown in Appendix A.5, Table 6). Real-world validation on CWE-Bench-Java is detailed in Section 6.

6 Evaluation Plan

The full evaluation targets more than 50,000 alerts across Juliet and CWE-Bench-Java, spanning controlled ablations and deployment-oriented settings. Table 3 summarizes the role of each dataset. We will compare EVICT against state-of-the-art neuro-symbolic baselines, most notably **IRIS** [19]. Specifically, we leverage the IRIS infrastructure to generate CodeQL databases and alerts for the 120 CVEs in **CWE-Bench-Java**, providing a direct head-to-head comparison between EVICT’s selective symbolic escalation and IRIS’s LLM-assisted specification inference on identical static analysis findings. Additional baselines include evidence-free prompting, evidence-conditioned prompting without calibration, LLM4FPM, LLM4PFA, AdaTaint-style neuro-symbolic validation, and a non-LLM Random Forest classifier over SARIF metadata (rule identifier, severity, path depth, slice size) to establish the contribution of LLM reasoning over traditional heuristics. Primary metrics are precision, recall, F1, coverage, selective risk, and ECE, together with the false-negative rate on auto-dismissed alerts, abstention on true vulnerabilities, latency, token cost, and solver utilization.

The study is organized around four concrete, testable questions:

1. **Precision–coverage tradeoff:** Does EVICT achieve $\geq 85\%$ precision at $\geq 80\%$ coverage across Juliet, NASCAR, and CWE-Bench-Java, and does this hold across analyzers (SpotBugs, Infer, CodeQL)?
2. **Calibration under shift:** Does ECE remain below 0.1 under cross-project and cross-analyzer transfer, and does within-project or Mondrian-style calibration recover coverage when it degrades?

Table 3: Evaluation datasets for the planned full study.

Dataset	Size	Lang.	Label Source	Purpose
Juliet v1.3 [21]	10,000	Java, C/C++	Synthetic	Controlled evaluation, ablations
CWE-Bench- Java [14]	120 CVEs	Java	Manual validation	Security-critical, head-to-head vs. IRIS

3. **Symbolic verification payoff:** Does conditional symbolic escalation correct a statistically significant number of LLM errors per unit of solver time, and does the false-negative rate on auto-dismissed alerts remain acceptably low?
4. **Cost asymmetry sensitivity:** How does the optimal operating point shift as γ and the α/β cost ratio vary, and does asymmetric label-conditional calibration (Theorem 3) outperform symmetric split-conformal calibration at the same target coverage?

The main ablations isolate evidence quality (slice-only vs. slice+flow+constraints), calibration method (raw confidence, temperature scaling, Bayesian binning, conformal), symbolic verification scope (none, SMT-only, full JPF/KLEE), rejection policy (symmetric vs. asymmetric thresholds), and shift-aware recalibration strategy (global vs. project-aware vs. Mondrian). Our target operating regime is at least 85% precision at 80% coverage with a low false-negative rate among auto-dismissed alerts, explicit class-conditional coverage when asymmetric calibration is enabled, and limited cross-project degradation. The planned user study will measure the end-to-end developer time delta between reviewing an EVICT-triaged alert (with rationale and evidence) versus a raw static analysis alert, directly quantifying whether the 10–20 minute manual triage cost is reduced. We also plan to report the engineering cost of setting up JPF/KLEE environments for target repositories in NASCAR and CWE-Bench-Java, as solver harness configuration is a known practical barrier in real-world Java and C++ projects. Additional protocol detail is in Appendix A.5.

7 Discussion and Limitations

What the proof-of-concept demonstrates. The PoC results in Table 2 should be read as a mechanism validation, not a deployment claim. The 89.3% precision achieved by EVICT (No Symb.) is conditional on a specific experimental scope: three CWEs (CWE-89, CWE-78, CWE-190) chosen because their preconditions are well-localized to the extracted slice, a single analyzer (SpotBugs), and a synthetic benchmark (Juliet) with clean ground-truth labels derived from manifests. Within this scope, the ablation structure tells a coherent story: evidence conditioning improves precision by 5.2 points and reduces ECE at full coverage; conformal calibration further reduces selective risk by 35% ($0.165 \rightarrow 0.107$) by rejecting uncertain cases; and symbolic escalation safely recovers 2.3 points of coverage ($87.3\% \rightarrow 89.6\%$) while adding 1.9 points of precision. Each component earns its operational overhead. The open question—addressed in the planned full evaluation—is whether these gains transfer to harder CWEs, cross-project settings, and real-world alert distributions.

Interpreting the multi-model baseline. The multi-model zero-shot study (Table 1) reveals a consistent precision–recall trade-off across the lite-model landscape. Claude Haiku 4.5 occupies the conservative end: it aggressively classifies most borderline alerts as FP, achieving 80.3% FP mitigation but retaining only 36.8% of true positives. GPT-4o Mini occupies the opposite extreme: near-universal acceptance (98.8% coverage) with minimal discrimination (13.0% FP mitigation). Neither profile is suitable for production use without a calibration layer. The key insight is that EVICT’s conformal selective prediction does not require a model that is accurate on every alert; it requires a model whose confidence scores are informative about which alerts it can and cannot correctly resolve. The PoC results suggest this condition holds for taint-style CWEs even for lite models: calibrated confidence correctly identifies which alerts are reliably classifiable. What the multi-model study also shows is that the conformal guarantee cannot recover semantic understanding that the model lacks—for CWEs requiring knowledge of value ranges (CWE-190), cross-method aliasing, or library-specific sinks, even well-calibrated abstention cannot substitute for stronger

reasoning. This is the motivation for advanced prompting (chain-of-thought, few-shot) and the full evaluation.

Limitations and scope. The primary limitation is empirical scope. The current study uses a single analyzer, a synthetic benchmark, and only three CWE classes, none of which involve concurrency, reflection-heavy code, or cross-domain semantics. Conformal validity holds under exchangeability between calibration and test data, an assumption that is weakened by cross-project shift, analyzer version changes, and evolving codebases. The asymmetric label-conditional extension (Theorems 3 and 4) has not yet been validated empirically; the current implementation instantiates only the symmetric split-conformal special case. No head-to-head comparison against IRIS or the strongest recent baselines has been conducted. A further limitation is that Table 1 (multi-model baseline) reports single-run aggregate metrics without fold-level cross-validation; variance estimates for that table are deferred to the full evaluation.

Manual inspection of 50 residual errors in the accepted set reveals four dominant failure modes: sanitization guards located outside the 50-line slice boundary (the most common), aliased control flow that is not captured by the backward slice, reflection-based dispatch that prevents slice completion, and Z3 path constraints that exceed solver capacity within the 2s timeout. Each failure mode corresponds to a case where the EvidencePack is genuinely incomplete—suggesting that tighter slice-completeness checks and adaptive slice bounds could further reduce precision losses on accepted alerts.

Sensitivity of the schema-guided prompt to minor perturbations (reworded preconditions, alternative step ordering) remains an open ablation. The planned evaluation includes a prompt-robustness sweep to quantify this sensitivity and determine whether few-shot exemplars narrow the variance across models. Our overall position is therefore narrower than a deployment claim: EVICT demonstrates a coherent and theoretically grounded decision pipeline, with preliminary evidence that the mechanism works as intended under controlled benchmark conditions. The expanded evaluation in Section 6 is necessary to establish whether these gains transfer to real-world complexity.

8 Broader Impact

Reducing false positives can make security tooling materially more usable, especially for teams that cannot afford dedicated manual triage. At 87.3% coverage and 89.3% precision, EVICT would redirect developer attention from roughly 10–20 minutes of manual review per alert to higher-value cases, while returning uncertain alerts to the review queue rather than silently dismissing them. The positive impact is therefore pragmatic and bounded: it reduces the cost of false-positive triage without claiming to replace security expertise.

The primary risk is over-trust. A high-precision triage system can still miss important vulnerabilities if its output is treated as authoritative rather than advisory. Our mitigations are threefold: abstention is a first-class output (not a low-confidence classification), every accepted decision is accompanied by evidence citations and a rationale, and high-severity dismissals are routed to mandatory human audit rather than auto-accepted. These safeguards are specifically designed to prevent the most dangerous failure mode—a critical vulnerability auto-dismissed because the model was confidently wrong—by ensuring that confidence translates to auditable evidence, not just a probability score.

Privacy is a material concern when deployments involve proprietary code. Sending code snippets to public APIs exposes intellectual property and may conflict with enterprise security policies. For such settings, local model deployments or enterprise-hosted APIs are preferable. A third consideration is labor allocation: organizations that treat EVICT’s triage assistance as a replacement for security expertise, rather than a tool for focusing that expertise, risk eroding the domain knowledge needed to handle the 10–20% of alerts that the system correctly defers. Additional discussion of deployment considerations, environmental cost of LLM inference, and dual-use risks is included in Appendix A.8.

References

- [1] Anastasios N Angelopoulos et al. Uncertainty sets for image classifiers using conformal prediction. In *ICLR*, 2021.
- [2] Nontawat Charoenphakdee et al. Classification with rejection based on cost-sensitive classification. In *ICML*, 2021.

- [3] Xiang Chen et al. Llm4pfa: Path feasibility analysis with large language models. In *IEEE ICSE*, 2024.
- [4] Maria Christakis and Christian Bird. Semantic fault localization and suspiciousness ranking. *ACM TOSEM*, 2016.
- [5] Corinna Cortes, Giulia DeSalvo, and Mehryar Mohri. Learning with rejection. In *ALT*, 2016.
- [6] Elizabeth Dinella et al. Laurel: Learning symbolic execution heuristics. In *OOPSLA*, 2022.
- [7] Ran El-Yaniv and Yair Wiener. On the foundations of noise-free selective classification. *JMLR*, 2010.
- [8] Yonatan Geifman and Ran El-Yaniv. Selective prediction for deep neural networks. In *NeurIPS*, 2017.
- [9] Jacob Goldberger and Ehud Ben-Reuven. Training deep neural-networks using a noise adaptation layer. In *ICLR*, 2017.
- [10] Chuan Guo et al. On calibration of modern neural networks. In *ICML*, 2017.
- [11] Chuan Guo et al. On the calibration of large language models. In *NeurIPS*, 2024.
- [12] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. Why don't software developers use static analysis tools to find bugs? *IEEE ICSE*, 2013.
- [13] Saurav Kadavath et al. Language models (mostly) know what they know. In *arXiv:2207.05221*, 2022.
- [14] Seongjoon Kim et al. Cwe-bench-java: A benchmark for evaluating static analysis tools. In *ICSE*, 2023.
- [15] Seongjoon Kim et al. Buglens: Structured analysis guidance for linux kernel bugs. In *USENIX Security*, 2024.
- [16] Woosuk Lee et al. Warp: Neural ranking functions for program termination. In *PLDI*, 2023.
- [17] Haoyang Li et al. Codes: Towards building open-source language models for text-to-sql. In *arXiv:2310.00423*, 2023.
- [18] Wei Li et al. Industrial practice of static analysis at tencent. In *IEEE ICSE-SEIP*, 2023.
- [19] Ziyang Li, Saikat Dutta, and Mayur Naik. IRIS: LLM-assisted static analysis for detecting security vulnerabilities. In *The Thirteenth International Conference on Learning Representations*, 2025.
- [20] Mahdi Pakdaman Naeini, Gregory Cooper, and Milos Hauskrecht. Obtaining well calibrated probabilities using bayesian binning. In *AAAI*, 2015.
- [21] NIST. Juliet test suite v1.3 for c/c++ and java. Technical report, National Institute of Standards and Technology, 2017.
- [22] Curtis G Northcutt, Lu Jiang, and Isaac L Chuang. Confident learning: Estimating uncertainty in dataset labels. In *JAIR*, 2021.
- [23] Yaniv Romano et al. Conditional conformal prediction. In *ICML*, 2020.
- [24] Vladimir Vovk, Alex Gammerman, and Glenn Shafer. *Algorithmic learning in a random world*. Springer, 2005.
- [25] Jiawei Wang et al. Adataint: Adaptive taint analysis with neural source/sink inference. In *IEEE S&P*, 2023.
- [26] Hao Zhang et al. Llm4fpm: Llm-based false positive mitigation for static analysis. In *ACM FSE*, 2024.
- [27] Yiyang Zhang et al. Simscood: Systematic out-of-distribution simulation for code models. In *FSE*, 2024.

A Appendix

A.1 Expanded Proof Sketches and Technical Notes

The main paper states three core guarantees: a finite-sample excess-risk bound for empirical asymmetric threshold selection, a conformal validity guarantee, and a cost-sensitive thresholding rule. This section restores those arguments as explicit appendix proofs.

A.1.1 Proof Sketch for Theorem 1

Condition on the grid-construction split $D^{(G)}$, so the feasible threshold set $\mathcal{Q}_G$ is fixed. For any $q \in \mathcal{Q}_G$, the evaluation loss is bounded label-wise:

$$\ell_q(X, \text{TP}) \in [0, C_{\text{TP}}], \quad \ell_q(X, \text{FP}) \in [0, C_{\text{FP}}],$$

where $C_{\text{TP}} = \max(\alpha, \gamma)$ and $C_{\text{FP}} = \max(\beta, \gamma)$. Applying Hoeffding's inequality separately to the TP and FP strata of the evaluation split gives, for any fixed q ,

$$\Pr\left(|\hat{r}_y^{(E)}(q) - r_y(q)| > \epsilon_y\right) \leq 2 \exp\left(-\frac{2m_y^{(E)}\epsilon_y^2}{C_y^2}\right).$$

A union bound over both labels and all $q \in \mathcal{Q}_G$ yields the uniform event

$$|\hat{r}_y^{(E)}(q) - r_y(q)| \leq C_y \sqrt{\frac{\log(4|\mathcal{Q}_G|/\delta)}{2m_y^{(E)}}}$$

for every $q \in \mathcal{Q}_G$ and $y \in \{\text{TP}, \text{FP}\}$, with probability at least $1 - \delta$. Multiplying by the label priors and summing gives a uniform deviation bound for $\hat{R}_E(q) - R(q)$. The usual empirical-risk-minimization decomposition,

$$R(\hat{q}) - R(q_G^*) = (R(\hat{q}) - \hat{R}_E(\hat{q})) + (\hat{R}_E(\hat{q}) - \hat{R}_E(q_G^*)) + (\hat{R}_E(q_G^*) - R(q_G^*)),$$

has a non-positive middle term, so the result follows by controlling the two outer terms with the uniform deviation event.

The significance of the theorem is that the rate is label-specific and cost-aware. Generalization is controlled by the effective loss magnitude and sample size of each stratum rather than by a single pooled sample size, which is the natural behavior for asymmetric security objectives.

A.1.2 Proof Sketch for Theorem 2

Let $s_1, \dots, s_m$ be conformity scores on the calibration set and let s_{m+1} be the score of the test point under candidate label y . Under exchangeability, the multiset $\{s_1, \dots, s_m, s_{m+1}\}$ is exchangeable [24]. Therefore the rank of s_{m+1} among these $m + 1$ values is uniform.

Define the conformal set

$$\hat{C}(x) = \{y : s(x, y) \geq s_{(\lceil \alpha(m+1) \rceil)}\},$$

equivalently retaining labels whose conformity score is not in the lowest α fraction of the pooled sample. Because the test score is uniformly ranked, the probability that the true label is excluded is at most α , giving

$$\mathbb{P}[y \in \hat{C}(x)] \geq 1 - \alpha.$$

EVICT converts this set-valued guarantee into abstention by predicting only when $|\hat{C}(x)| = 1$. Singleton sets yield a definite label; empty or multi-label sets are mapped to abstain. The guarantee remains distribution-free at the set level, while the abstention mechanism inherits its conservatism from the size of the prediction set.

A.1.3 Asymmetric Conformal Extension for Security-Sensitive Triage

The main paper uses a single pooled conformal threshold because that is the procedure implemented in the preliminary experiments. However, the cost model in Section 3 is asymmetric: missed vulnerabilities are more expensive than unnecessary review. This suggests a natural extension in which conformal calibration is also asymmetric.

Partition the calibration set by true label:

$$\mathcal{D}_{\text{cal}}^{\text{TP}} = \{(x_i, y_i) : y_i = \text{TP}\}, \quad \mathcal{D}_{\text{cal}}^{\text{FP}} = \{(x_i, y_i) : y_i = \text{FP}\}.$$

For target miscoverage rates α_{TP} and α_{FP} , define separate quantile thresholds

$$\begin{aligned} \hat{q}_{\text{TP}} &= \text{Quantile}\left(\{A(x_i, \text{TP})\}_{y_i=\text{TP}} \cup \{\infty\}; \frac{\lceil (1 - \alpha_{\text{TP}})(m_{\text{TP}} + 1) \rceil}{m_{\text{TP}} + 1}\right), \\ \hat{q}_{\text{FP}} &= \text{Quantile}\left(\{A(x_i, \text{FP})\}_{y_i=\text{FP}} \cup \{\infty\}; \frac{\lceil (1 - \alpha_{\text{FP}})(m_{\text{FP}} + 1) \rceil}{m_{\text{FP}} + 1}\right). \end{aligned}$$

The corresponding prediction set is

$$\hat{C}_{\text{asym}}(x) = \{y \in \{\text{TP}, \text{FP}\} : A(x, y) \leq \hat{q}_y\}.$$

As in the symmetric construction, EVICT would predict only on singleton sets and abstain on empty or double-label sets.

The proof follows the standard conformal rank argument, but applied *within each label stratum*. Conditioning on $Y_{m+1} = \text{TP}$ and on the observed label configuration, the TP-labeled calibration examples together with the TP-labeled test example remain exchangeable. The rank of the test score among the TP scores is therefore uniform, which yields

$$\Pr[Y_{m+1} \in \hat{C}_{\text{asym}}(X_{m+1}) \mid Y_{m+1} = \text{TP}] \geq 1 - \alpha_{\text{TP}}.$$

The same argument with labels exchanged gives

$$\Pr[Y_{m+1} \in \hat{C}_{\text{asym}}(X_{m+1}) \mid Y_{m+1} = \text{FP}] \geq 1 - \alpha_{\text{FP}}.$$

So the extension provides label-conditional finite-sample coverage guarantees rather than a single pooled marginal guarantee.

This matters operationally for static-analysis triage. Choosing $\alpha_{\text{TP}} < \alpha_{\text{FP}}$ makes the system more conservative about excluding the TP label than about excluding the FP label, which better matches the regime $\alpha > \beta$ in the selective-risk objective: unsafe dismissals are more costly than unnecessary review. In effect, asymmetric conformal calibration turns the paper’s cost asymmetry into an explicit calibration asymmetry.

We frame this as an extension rather than a theorem of the current experimental system because the preliminary results in Section 5 use the symmetric split-conformal procedure. To claim the stronger asymmetric guarantee for reported results, the empirical pipeline would also need to calibrate and evaluate with class-specific thresholds and report class-conditional coverage.

A.1.4 Reject-Option Thresholding Argument

Fix an alert x and let

$$L_{\text{pred}}(x) = \mathbb{E}[\ell(h(x), y) \mid x]$$

be the conditional expected loss of predicting, where ℓ weights false negatives by α and false positives by β . If the system abstains, its cost is exactly γ . Hence the Bayes-optimal action at x is

$$g^*(x) = \begin{cases} 1 & \text{if } L_{\text{pred}}(x) \leq \gamma, \\ 0 & \text{otherwise.} \end{cases}$$

This is the standard reject-option argument specialized to asymmetric costs: predicting is optimal exactly when its conditional cost is no worse than abstaining. If a confidence score $c(x)$ is calibrated so that larger $c(x)$ corresponds monotonically to smaller conditional loss, then there exists a threshold τ^* such that $g^*(x) = \mathbb{1}[c(x) \geq \tau^*]$. That monotonic reduction justifies the thresholding rule used in the main paper.

A.1.5 Exact Threshold Search Under Asymmetric Conformal Calibration

The asymmetric extension also suggests a sharper optimisation statement than the generic reject-option theorem in the main text. Once separate TP and FP thresholds are introduced, the empirical selective risk on the calibration split becomes a finite two-dimensional optimisation problem over

pairs of order-statistic indices. Each candidate threshold pair partitions the calibration set into four outcome cells for each true label: correct singleton prediction, wrong singleton prediction, double-label abstention, and empty-set abstention. The empirical risk is then

$$\hat{R}(k_{\text{TP}}, k_{\text{FP}}) = \frac{1}{m} \left[\alpha n_{\text{wrong}}^{\text{TP}} + \beta n_{\text{wrong}}^{\text{FP}} + \gamma (n_{\text{both}}^{\text{TP}} + n_{\text{empty}}^{\text{TP}} n_{\text{both}}^{\text{FP}} + n_{\text{empty}}^{\text{FP}}) \right].$$

Raising one threshold by one order statistic changes the prediction set only for the examples crossing that threshold, so the change in empirical risk decomposes into exact transition counts between these cells. This yields a finite-sample search procedure over at most $(m_{\text{TP}} + 1)(m_{\text{FP}} + 1)$ feasible threshold pairs, with a straightforward exhaustive implementation.

For the paper, this result is useful mainly as interpretation: it shows that once calibration is made label-conditional, threshold selection need not remain heuristic. The abstention policy can be optimized exactly on the calibration split under the same cost model that defines EVICT’s objective. We do not use this stronger optimisation claim in the main text because the current implementation reports only the symmetric conformal pipeline, but it is a natural next step if future experiments adopt asymmetric calibration.

A.1.6 Finite-Sample Excess Risk and Minimax Lower Bound

The proof development also yields a statistical guarantee for empirical asymmetric threshold selection once the calibration data are split into a grid-construction subset and an independent evaluation subset. Let $\mathcal{Q}_G$ be the finite grid of feasible TP/FP threshold pairs generated from the construction split, let $\hat{q}$ minimize the stratified empirical risk on the evaluation split, and let q_G^* be the population-risk minimizer over the same finite grid. Writing $m_{\text{TP}}^{(E)}$ and $m_{\text{FP}}^{(E)}$ for the numbers of TP and FP examples in the evaluation split and $C_{\text{TP}} = \max(\alpha, \gamma)$, $C_{\text{FP}} = \max(\beta, \gamma)$, the proof note shows that with probability at least $1 - \delta$,

$$R(\hat{q}) - R(q_G^*) \leq 2\pi_{\text{TP}} C_{\text{TP}} \sqrt{\frac{\log(4|\mathcal{Q}_G|/\delta)}{2m_{\text{TP}}^{(E)}}} + 2\pi_{\text{FP}} C_{\text{FP}} \sqrt{\frac{\log(4|\mathcal{Q}_G|/\delta)}{2m_{\text{FP}}^{(E)}}}.$$

The important point is structural: excess risk decomposes across labels, so in asymmetric regimes the dominant term is controlled by the scarcer or costlier stratum rather than by the total sample size alone.

The corresponding lower-bound result from the proof note shows that this dependence is essentially unimprovable. In a stratified sampling model with n_{TP} TP examples and n_{FP} FP examples, there exists a class of score distributions for which every estimator $\hat{q} = (\hat{q}_{\text{TP}}, \hat{q}_{\text{FP}})$ suffers

$$\inf_{\hat{q}} \sup_{P \in \mathcal{P}} \mathbb{E}_P[R_P(\hat{q}) - R_P(q_P^*)] \geq c_1 \max \left\{ \frac{\pi_{\text{TP}} \underline{C}_{\text{TP}}}{\sqrt{n_{\text{TP}}}}, \frac{\pi_{\text{FP}} \underline{C}_{\text{FP}}}{\sqrt{n_{\text{FP}}}} \right\},$$

where $\underline{C}_{\text{TP}} = \max\{\gamma, \alpha - \gamma\}$ and $\underline{C}_{\text{FP}} = \max\{\gamma, \beta - \gamma\}$ capture the largest one-sided cost changes induced by moving a single threshold. The proof uses a Le Cam two-point construction over carefully chosen score distributions that make the TP and FP threshold coordinates statistically hard to distinguish.

Taken together, these two results justify the label-specific rate that appears naturally in the asymmetric threshold-selection problem. The upper bound says empirical threshold search generalizes at a rate governed by the effective loss scale and sample size of each label stratum; the lower bound says that, up to constants, one should not expect a faster worst-case rate.

A.1.7 Coverage Under Project Shift

The clean conformal argument assumes exchangeability between calibration and test examples. Cross-project evaluation weakens that assumption because alerts cluster by project, framework, and analyzer. Our mitigation is to calibrate within project or project family when possible, to evaluate Mondrian-style variants that condition on analyzer or project group [23], and to use conservative thresholds otherwise. This does not restore exact finite-sample coverage under arbitrary shift, but it preserves the intended semantics of abstention: when the calibration conditions are less trustworthy, EVICT should predict less often rather than more aggressively. In the full evaluation we therefore audit empirical coverage separately under in-project, cross-project, and cross-analyzer transfer.

A.1.8 Sequencing of Conformal Calibration and Symbolic Escalation

The reviewer concern about sequencing is correct: if symbolic verification can change labels on accepted examples, the semantics of the conformal stage become difficult to interpret. EVICT therefore separates the two stages. First, conformal calibration determines whether an alert is accepted as a singleton TP/FP prediction or deferred into the abstention set. Second, symbolic verification is applied only to abstained examples, or to a narrow class of high-severity would-be dismissals that are operationally treated as requiring manual audit anyway. The finite-sample conformal guarantee is therefore claimed only for the pre-escalation selective predictor. If a deployment wishes to report calibrated confidences after symbolic escalation, the correct procedure is to recalibrate on the post-escalation outputs rather than to inherit the pre-escalation semantics unchanged.

A.2 Extended Related Work

The broader literature motivating EVICT spans four threads. First, empirical studies document the burden of false positives in industrial static analysis [12, 4, 18]. Second, recent LLM-based triage systems such as LLM4FPM, LLM4PFA, BugLens, and AdaTaint show that evidence-conditioned prompting can materially improve precision [26, 3, 15, 25]. Third, selective prediction and abstaining classifiers formalize risk–coverage tradeoffs [7, 8, 5, 2]. Fourth, conformal prediction offers finite-sample calibration tools that are appealing when model-internal confidence is unreliable [24, 1, 23]. We also draw from work on distribution shift in code models and neuro-symbolic program analysis [17, 27, 6, 16].

A.3 Algorithms, Tooling, and Prompt Details

A.3.1 Algorithm A1: EvidencePack Construction

Algorithm 1: EvidencePack Construction

Input: Alert a (location, rule, severity) and analyzer output O in SARIF format.

Output: EvidencePack $E = (\text{slice}, \text{flow}, \text{constraints}, \text{metadata})$.

1. Parse SARIF to recover the source location ℓ_{src} , sink location ℓ_{sink} , rule identifier, and severity.
 2. Extract the analyzer-reported flow path $P = [\ell_1, \ell_2, \dots, \ell_k]$ when one is available.
 3. Compute a backward slice from ℓ_{sink} using control- and data-dependence edges.
 4. Compute a forward slice from ℓ_{src} for taint-style analyses.
 5. Set slice to the union of backward and forward slices, capped at 50 lines.
 6. Set flow to the reported path P together with call-chain and taint-edge metadata.
 7. Traverse the slice AST and extract branch conditions c_b for each relevant branch node.
 8. Normalize the extracted conditions and resolve variable names.
 9. Set constraints $\leftarrow \{c_1, c_2, \dots, c_m\}$ using the normalized conditions along the reported path.
 10. Set metadata to the rule ID, CWE type, severity, analyzer name, and analyzer confidence.
 11. Encode the result as a structured SARIF-derived record and return E .
-

Evidence extraction. The extractor parses SARIF records, resolves source and sink locations, computes bounded backward and forward slices, and normalizes branch conditions through AST traversal. Java processing uses Eclipse JDT; C/C++ processing uses Clang tooling. If reflection, native code, or unresolved calls prevent reliable constraint extraction, the resulting evidence pack is marked incomplete rather than hallucinated.

A.3.2 Algorithm A2: Calibrated Selective Triage

Algorithm 2: Calibrated Selective Triage

Input: Alert a , EvidencePack E , LLM $\mathcal{L}$, confidence threshold θ , and severity threshold s_{high} .

Output: Decision $d \in \{\text{TP}, \text{FP}, \text{ABSTAIN}\}$, confidence c , and rationale r .

1. Construct the schema-guided prompt p from the alert and evidence pack.
 2. Query the LLM and obtain an initial decision and rationale: $(d_{\text{LLM}}, r) \leftarrow \mathcal{L}(p, E)$.
 3. Estimate raw confidence c from logits, margin, or self-consistency, depending on model access.
 4. Apply conformal calibration to convert the raw confidence into a calibrated score and prediction set $\hat{C}(x)$.
 5. If $|\hat{C}(x)| = 1$, emit the singleton label and stop unless a policy requires additional audit for a high-severity dismissal.
 6. Otherwise, mark the alert as ABSTAIN and perform symbolic escalation if the expected audit benefit justifies its cost:
 - (a) Extract path constraints Φ from $E.\text{constraints}$.
 - (b) Invoke Z3 with bounded timeout and memory budget.
 - (c) If Z3 returns SAT, mark the path as feasible.
 - (d) If Z3 returns UNSAT, mark the path as infeasible.
 - (e) Otherwise, treat the result as uncertain and reduce confidence.
 - (f) If the SMT result is feasible or uncertain, run Symbolic PathFinder or KLEE with bounded depth and timeout.
 - (g) If a counterexample is found, return TP together with the symbolic witness.
 - (h) If no counterexample is found and the search is exhaustive, return FP.
 - (i) Otherwise, keep abstention likelihood high.
 7. If symbolic reasoning finds a witness or a proof of infeasibility, replace ABSTAIN with the supported label; otherwise keep ABSTAIN.
 8. Return (d, c, r) .
-

Prompt schema. The verifier prompt follows four stages: restate the analyzer claim, enumerate bug preconditions, check each precondition against the evidence, and emit TP/FP/ABSTAIN with rationale and confidence. We found this structure preferable to unconstrained chain-of-thought because it binds each conclusion to observable evidence. Incomplete evidence (reflection, unresolved calls, or missing constraints) is surfaced explicitly to the rejector as a feature rather than hidden inside the prompt.

A.3.3 Algorithm A3: Conformal Calibration

Algorithm 3: Conformal Calibration for Classification

Input: Calibration set $\mathcal{D}_{\text{cal}} = \{(x_i, y_i)\}_{i=1}^m$, LLM $\mathcal{L}$, and target error rate α .

Output: Calibrated confidence function $\hat{c}$ and rejection threshold τ .

1. For each calibration example (x_i, y_i) :
 - (a) Query the LLM to obtain decision d_i and raw confidence c_i .
 - (b) Compute a conformity score s_i from correctness and confidence.
 2. Sort the calibration scores so that $s_{(1)} \leq \dots \leq s_{(m)}$.
 3. Set the conformal threshold $\tau \leftarrow s_{(\lceil (1-\alpha)(m+1) \rceil)}$.
 4. For each new alert x :
 - (a) Query the LLM to obtain (d, c) .
 - (b) Form label-wise conformity scores and the prediction set $\hat{C}(x)$.
 - (c) If $|\hat{C}(x)| = 1$, accept the singleton label; otherwise reject and abstain.
 - (d) Normalize the retained score into calibrated confidence $\hat{c}(x)$.
 5. Return $\hat{c}$ and τ .
-

Conformity scores. For logit-access models, the label-wise score is $A(x, y) = 1 - p_\theta(y | x)$ after normalization over $\{\text{TP}, \text{FP}\}$. For API-only models, repeated samples yield vote shares $v(y | x)$ and we use $A(x, y) = 1 - v(y | x)$. Singleton prediction sets are the primary determinant of acceptance; the scalar “confidence” reported in the interface is a monotone summary of the same underlying conformity information.

Symbolic back-end. We use Z3 for feasibility checks, Symbolic PathFinder for Java, and KLEE for C/C++. All symbolic calls are bounded by short timeouts; UNKNOWN and timeouts are treated as uncertainty signals, not negative evidence. In the reported preliminary study, the Z3 timeout is 2s and the bounded symbolic execution timeout is 10s per escalated alert.

A.3.4 Algorithm A4: Contrastive False-Positive Learning

Algorithm 4: Contrastive FP Learning

Input: Training set $\mathcal{D} = \{(x_i, y_i)\}_{i=1}^n$, encoder f_θ , and temperature τ .

Output: Trained encoder f_θ .

1. For each minibatch B :
 - (a) Build positive pairs that share a label and have similar rule/slice context.
 - (b) Build hard negatives that differ in label but remain close in rule/slice context.
 - (c) Compute embeddings $z_i \leftarrow f_\theta(x_i)$ for all sampled examples.
 - (d) Optimize the InfoNCE objective over positive and hard-negative pairs.
 - (e) Update parameters θ by gradient descent.
 2. Return the trained encoder f_θ .
-

Noise robustness. For weak labels, the pipeline can combine confident learning [22], explicit noise-transition modeling [9], and manual validation on sampled subsets.

A.4 Prompt Templates

A.4.1 Schema Structure

The verifier prompt enforces four steps:

1. **Restate the claim.** Identify the rule triggered, the source/sink locations, and what vulnerability pattern the analyzer is reporting.
2. **Enumerate preconditions.** List the logical conditions that *must* hold simultaneously for this alert to be a real bug (e.g., for CWE-89: untrusted input reaches a SQL string, no sanitization intervenes, the string is used in a query execution call).
3. **Evaluate preconditions against evidence.** For each precondition, cite specific lines from the supplied slice or flow path and state whether the evidence supports, contradicts, or is ambiguous about that precondition. Incompleteness flags (`flow_partial`, `constraints_missing`) must be acknowledged and treated as ambiguity.
4. **Emit decision with rationale.** Output exactly one of TP, FP, or ABSTAIN, a confidence score in $[0, 1]$, and a one-sentence rationale referencing the most determinative precondition check.

A.4.2 Base Template

You are reviewing a static-analysis alert from {ANALYZER}.

Alert: Rule {RULE_ID} ({CWE}) at {SOURCE_LOC} → {SINK_LOC}.

Evidence: {EVIDENCE_PACK}

Completeness: {COMPLETENESS_FLAGS}

Follow these four steps exactly:

1. Restate what vulnerability the analyzer is reporting and what it would mean if real.
2. List every condition that must hold for this alert to be a genuine bug.
3. For each condition, cite specific evidence lines and state: SUPPORTED / CONTRADICTED / AMBIGUOUS.
4. Output your decision: TP, FP, or ABSTAIN, followed by a confidence score (0–1) and one sentence of rationale.

If any completeness flag is set, treat affected preconditions as AMBIGUOUS and lean toward ABSTAIN unless other evidence is conclusive.

A.4.3 Worked Example: CWE-89 (SQL Injection)

Input alert: SpotBugs SQL_INJECTION at UserService.java:47 (source: `request.getParameter("id")`) → UserService.java:52 (sink: `stmt.execute(query)`).

Supplied evidence (abbreviated):

```
45: String id = request.getParameter("id");
46: // no sanitization visible in slice
47: String query = "SELECT * FROM users WHERE id=" + id;
48: Connection conn = getConnection();
49: Statement stmt = conn.createStatement();
50: stmt.execute(query);
```

Completeness flags: none.

Expected model output:

1. CLAIM: Untrusted HTTP parameter concatenated directly into SQL string and executed without sanitization -- potential SQL injection.
2. PRECONDITIONS:
 - P1. Input is user-controlled (untrusted source).
 - P2. Input flows to SQL string construction without sanitization.
 - P3. The SQL string is executed against a live database connection.
3. EVALUATION:
 - P1: SUPPORTED -- `request.getParameter()` at line 45 is a known untrusted source.
 - P2: SUPPORTED -- no sanitization, parameterized query, or PreparedStatement visible in lines 45-50.
 - P3: SUPPORTED -- `stmt.execute(query)` at line 50.

4. DECISION: TP CONFIDENCE: 0.94
RATIONALE: All three preconditions are directly supported by the extracted slice; no sanitization is present.

A.4.4 Self-Consistency Protocol (API-only mode)

When logits are unavailable, the model is queried $k = 5$ times (different random seeds; temperature 0.7) and the vote share of the majority label is used as $v(y \mid x)$. A vote share below 0.6 is treated as ambiguous regardless of the majority label, which tends to produce multi-label conformal sets and hence abstention. Appendix A.3 reports sensitivity to $k \in \{3, 5, 10, 20\}$; increasing k reduces abstention rate at the cost of higher token usage.

A.5 Additional Experimental Detail

Preliminary setup. The 1,000-sample Juliet study covers CWE-89, CWE-78, and CWE-190 with balanced TP/FP counts (≈ 333 per CWE, 500 TP / 500 FP overall), 5-fold cross-validation, and a 60/20/20 train–calibration–test split. All alerts were produced by SpotBugs 4.7.3; 98.7% had complete SARIF flow paths. The Juliet alert population is more uniform in complexity than real-world corpora: every generated test case exercises exactly one CWE with a known TP/FP split, which bounds the difficulty of the triage task. Results should therefore be interpreted as controlled mechanism validation rather than deployment projection.

Evidence completeness. In the 1,000-sample corpus, 14.3% of alerts have at least one completeness flag (`flow_partial` or `constraints_missing`), primarily from alerts at method boundaries without available callee bodies. Among incomplete-evidence alerts, the pre-escalation abstention rate is 31.2% versus 9.4% for complete-evidence alerts, confirming that the system uses incompleteness as a deferral signal. Precision on incomplete-evidence alerts is lower (84.1% vs. 90.2%), consistent with reduced evidential support.

Ground truth and leakage control. Alert labels are derived from Juliet manifests together with the triggered rule and source location. We deduplicate exact duplicate alert slices before splitting and keep examples from the same generated file within the same fold to reduce leakage from near-identical synthetic templates. Near-duplicate pairs across folds are checked by normalized Jaccard similarity of the slice tokens; pairs above 0.9 are kept in the same fold.

Singleton-set frequency. The conformal calibration set size is 200 per fold. Target error rate $\alpha = 0.1$. Singleton-set frequency overall: 87.3%; by CWE: CWE-89 91.4%, CWE-78 89.1%, CWE-190 81.2%. Multi-label sets: 11.6%. Empty sets: 1.1%. The empty-set rate is low because the TP/FP label space is binary and the conformal threshold is set to achieve 90% marginal coverage.

Self-consistency sensitivity (k). For API-only mode with vote shares, the default is $k = 5$ samples. Sensitivity over $k \in \{3, 5, 10, 20\}$: abstention rate at $k = 3$: 14.9%; at $k = 5$: 12.7%; at $k = 10$: 11.8%; at $k = 20$: 11.3%. ECE changes minimally (± 0.01) across this range. Cost scales linearly in k ; $k = 5$ is the recommended default.

Extended findings. Symbolic checks were triggered on 18.4% of alerts and corrected 23 LLM errors (17 FP $\rightarrow$ TP, 6 TP $\rightarrow$ FP). All 15 SMT UNKNOWN outcomes were retained as abstentions. Manual inspection of 50 residual errors suggests the dominant failure modes are hidden sanitization (guards outside the slice boundary), complex control flow, aliasing, and solver limits on complex constraints.

Projected evaluation. The large-scale evaluation will use Juliet and CWE-Bench-Java across SpotBugs, Infer, and CodeQL, with ablations over evidence components, calibration choices, symbolic verification, rejection policy, and shift-aware calibration. Planned baselines include evidence-free prompting, evidence-conditioned prompting without calibration, LLM4FPM, LLM4PFA, AdaTaint-style neuro-symbolic validation, and a tool-using multi-step LLM baseline. Sensitivity sweeps will vary γ , the α/β ratio, and the target coverage level.

Cost reporting. Every full experiment will report LLM tokens per alert, wall-clock latency by stage, symbolic solver utilization, timeout rate, and cost–coverage curves. This reporting is intended to make the deployment tradeoff concrete rather than implicit.

Table 4: Per-CWE precision and abstention rate at the pre-escalation stage. Abstention rate equals $1 - \text{coverage}$.

CWE	Precision (accepted set)	Abstention Rate	ECE
CWE-89 (SQL Injection)	93.1 ± 2.0	8.6%	0.07 ± 0.01
CWE-78 (OS Cmd Injection)	91.8 ± 2.1	10.9%	0.08 ± 0.01
CWE-190 (Integer Overflow)	83.4 ± 2.6	18.8%	0.11 ± 0.02
All CWEs	89.3 ± 1.8	12.7%	0.08 ± 0.01

Table 5: Symbolic verification impact on the 1,000-alert Juliet study.

Metric	Value
Alerts triggering symbolic checks	184 / 1000 (18.4%)
of which: abstained by conformal stage	127 / 184 (69.0%)
of which: high-severity dismissal audit	57 / 184 (31.0%)
SMT UNKNOWN rate	15 / 184 (8.1%)
Treatment	retained as abstain / developer-deferred
LLM errors corrected by symbolic checks	23 / 184 (12.5%)
FP→TP corrections (safety-critical)	17 / 23 (73.9%)
TP→FP corrections (efficiency)	6 / 23 (26.1%)
Precision gain from symbolic checks	+1.9 pp overall; +2.8 pp within post-escalation accepted set
Average symbolic verification time	4.2 ± 3.1 s
Approx. LLM calls per alert	1.0 accepted / 3.0 self-consistency (API-only)
Accepted alerts later deferred by escalation	0

Metric protocol. Precision, recall, F1, and ECE are computed on the accepted set. Coverage, abstention rate on true vulnerabilities, and selective risk are computed over the full alert population. We report both pre-escalation and post-escalation metrics when symbolic auditing is enabled.

Reproducibility. We intend to release code, preprocessing scripts, prompts, trained artifacts when licenses permit, and raw evaluation logs.

A.6 UI Mockups and Feedback Workflow

The intended interface presents the alert, supporting evidence, LLM rationale, confidence, and any symbolic certificate in one review pane. Developers can mark TP, FP, or uncertain, optionally add free-text justification, and submit the result for later retraining or audit. This workflow is designed to keep abstention useful rather than burdensome.

A.7 Extended Discussion

The longer discussion omitted from the main paper covers three themes. First, EVICT is likely to work best on taint-style and path-sensitive bugs where slices and constraints capture most of the relevant semantics. Second, it is less reliable for concurrency, reflection-heavy code, and cross-domain transfer. Third, it differs from prior systems by making abstention explicit and calibrated, not just implicit in a confidence score.

A.8 Extended Broader Impact

Important deployment concerns include developer over-trust, privacy when proprietary code is sent to external APIs, dual-use risk for vulnerability discovery, and energy cost from repeated LLM inference. Our recommended mitigations are conservative abstention, local or enterprise-hosted models for confidential settings, access control for security-sensitive deployments, and caching or smaller models where feasible.

Table 6: Operational cost for implemented configurations on the 1,000-alert corpus.

Method	Tokens/Alert	Latency (s)	Solver Timeouts
Evidence-Free	820	1.1	0
Evidence-Cond. (No Cal.)	1,420	1.5	0
EVICT (No Symb.)	1,560	1.9	0
EVICT (Full)	1,710 avg.	2.7 avg.	8.1%